

Narrativa Explicativa – Marco QM + PRAGMATIC

Donde las métricas dejan de ser listas interminables de números y pasan a tener propósito.

1. Por qué combinar QM y PRAGMATIC

En el ámbito de la ciberseguridad nacional, es fácil caer en dos extremos igualmente poco útiles:

- Acumular métricas sin un propósito claro, hasta tener dashboards impresionantes que no cambian ninguna decisión.
- O limitarse a declaraciones de alta política sin traducirlas nunca en datos concretos y medibles.

La combinación de **QM (Goal-Question-Metric)** con los criterios **PRAGMATIC** pretende cerrar ese abismo:

- QM garantiza que cada dato responde a una pregunta y cada pregunta sirve a un objetivo.
- PRAGMATIC ayuda a evaluar si las métricas elegidas son realmente buenas compañeras de viaje o simples cifras decorativas.

2. De objetivos nacionales a preguntas concretas

Partimos de objetivos nacionales relativamente solemnes (mejorar la resiliencia, reducir vulnerabilidades, fortalecer la cadena de suministro...). Con QM, esos objetivos se descomponen en preguntas concretas:

- “¿Qué porcentaje de sistemas críticos tiene realmente un modelo de amenazas actualizado?”
- “¿Cuántas vulnerabilidades explotadas activamente llevamos arrastrando desde hace más de un año?”
- “¿Cuánto tardamos en detectar y contener incidentes significativos?”

Cada pregunta conecta la política con la realidad operativa. A partir de ahí, definimos las **métricas** que responden a esas preguntas y que pueden ser recogidas de forma razonable por las organizaciones.

3. La prueba del algodón: PRAGMATIC

No todas las métricas son igual de útiles. Algunas son fáciles de medir pero dicen poco; otras serían estupendas en teoría, pero inalcanzables en la práctica. Aquí entran los criterios PRAGMATIC:

- Predictiva: ¿Esta métrica nos avisa antes de que algo grave ocurra?
- Relevante: ¿Mide algo que realmente le importa al país, al sector o a la organización?
- Accionable: Si la métrica se mueve, ¿sabemos qué tecla tocar?
- Genuina: ¿Refleja la situación real, o invita a “maquillarla” para quedar bien?
- Significativa: ¿La entienden los decisores sin necesidad de un intérprete simultáneo?
- Precisa: ¿Los datos son suficientemente robustos para tomar decisiones serias?
- Oportuna: ¿Llega a tiempo, o cuando se analiza ya es arqueología digital?
- Independiente: ¿Evita los incentivos perversos (por ejemplo, esconder incidentes para “mejorar” el indicador)?
- Rentable: ¿El esfuerzo y el coste de medir compensan el valor que aporta?

La matriz PRAGMATIC puntúa cada métrica en estos nueve ejes. Una métrica con buena puntuación global es candidata a quedarse; una que puntúe mal puede considerarse para revisión o eliminación.

4. Aplicación práctica a indicadores VAST

Cuando hablamos de métricas inspiradas en el enfoque VAST, solemos referirnos a cosas como:

- Porcentaje de sistemas críticos con modelos de amenazas vigentes.
- Frecuencia de revisión de dichos modelos.
- Nivel de integración del modelado de amenazas en el SDLC/CI-CD.
- Cobertura de vulnerabilidades explotadas activamente y sus tiempos de remediación.

El marco GQM permite anclar esas métricas a objetivos claros, por ejemplo:

- “Aumentar la capacidad de anticipación frente a ataques dirigidos a servicios esenciales.”

PRAGMATIC, por su parte, permite decir cosas como:

- “Esta métrica es predictiva y accionable, pero costosa de obtener; necesitamos automatizar parte de la recogida.”
- “Esta otra métrica es barata de medir, pero apenas añade información útil; quizá sea hora de dejarla marchar.”

5. Uso del marco en la práctica

Un posible proceso pragmático (valga la redundancia) sería:

1. Definir objetivos nacionales: por ejemplo, los seis grandes objetivos G1–G6 del marco VAST nacional.
2. Derivar preguntas clave que el regulador y los responsables de ciber quieren responder.
3. Seleccionar un conjunto limitado de métricas por objetivo, evitando la inflación de indicadores.
4. Evaluar cada métrica contra PRAGMATIC con un pequeño grupo de expertos.
5. Ajustar el catálogo: reforzar, redefinir o eliminar métricas según su puntuación PRAGMATIC.
6. Integrar las métricas resultantes en plantillas de encuesta, modelos de reporte y herramientas técnicas.

El resultado ideal es un conjunto de indicadores que no solo llenan informes, sino que orientan decisiones: presupuesto, prioridades de mitigación, regulación, formación, etc.

6. Beneficios para los distintos actores

- Responsables nacionales y reguladores: disponen de indicadores comparables entre sectores, con trazabilidad a objetivos políticos y normativos.
- CISOs y responsables técnicos: ven claro qué datos recopilan, por qué y cómo se usarán, evitando la sensación de “reportar por reportar”.
- Alta dirección: recibe un conjunto reducido de métricas significativas, conectadas con riesgo y continuidad del negocio.
- Sector académico y de investigación: accede a un marco estructurado que facilita estudios longitudinales y comparativos.

7. Limitaciones y cautelas

Ningún marco de métricas, por elegante que sea, sustituye al juicio experto. Algunas cautelas razonables:

- No confundir el valor de una métrica con el valor del objetivo: una métrica puede mejorar mientras el contexto empeora (por ejemplo, se remedia más rápido, pero la superficie de ataque crece aún más rápido).
- Evitar usar métricas exclusivamente como herramienta de presión o castigo: eso incentiva el maquillaje de datos.
- Revisar periódicamente las métricas: lo que hoy es útil puede dejar de serlo en pocos años.

8. Cierre

El marco GQM+PRAGMATIC no pretende ser un dogma, sino un antídoto contra dos males bastante extendidos: la métrica irrelevante y la decisión sin datos.

Si, después de aplicarlo, su organización acaba con menos indicadores, pero mejores, el ejercicio habrá merecido la pena. Y si además esos indicadores sirven para sostener conversaciones más maduras entre técnicos, directivos y reguladores, entonces estaremos, al menos, modelando bien las amenazas de la ignorancia.